



REPORTE DE ACTIVIDAD 7

Nombre del proyecto: LAB: FILE PATH TRAVERSAL SIMPLE CASE

Nivel: Apprentice

Nombre: Karla Vanessa Glz Espinoza

TIPO DE EXPLOTACIÓN

Path Traversal (Directory Traversal) / CWE-22: Improper Limitation of a Pathname to a Restricted Directory ('Path Traversal').

OBJETIVO DEL LABORATORIO

El objetivo de este entorno de pruebas es explotar una vulnerabilidad de salto de directorio (Path Traversal) en la funcionalidad de visualización de imágenes de productos de la aplicación web, con la finalidad de leer el archivo sensible `/etc/passwd` del sistema operativo subyacente.

EXPLICACIÓN TÉCNICA

El Path Traversal, también conocido como Directory Traversal, es una vulnerabilidad de seguridad web crítica que permite a un atacante leer archivos arbitrarios en el servidor que ejecuta la aplicación. Esto incluye código fuente de la aplicación, credenciales, archivos de configuración del sistema operativo y otros datos sensibles (OWASP Foundation, 2023).

De acuerdo con la tríada de la seguridad de la información (CIA), esta vulnerabilidad compromete de manera directa la Confidencialidad de los datos, ya que expone información a la que el usuario no debería tener acceso (CISA, 2022).

La vulnerabilidad ocurre cuando la aplicación web recibe entradas del usuario (en este caso, a través de parámetros en la URL) para construir la ruta de un archivo, pero no implementa los mecanismos de validación ni desinfección adecuados. En un escenario vulnerable, un atacante puede utilizar secuencias de caracteres de "salto de directorio" (como `../`) para escapar del directorio raíz o de trabajo previsto por la aplicación, forzando al servidor web a navegar hacia atrás en la jerarquía del sistema de archivos y retornar el contenido de archivos del sistema operativo (MITRE, 2023).

PROCEDIMIENTO

Paso 1: Se inició la máquina de laboratorio utilizando las credenciales provistas por Web Security Academy y se configuró la herramienta Burp Suite Community Edition como proxy HTTP.

Paso 2: Se navegó a la página principal de la tienda y se seleccionó el apartado "View details" de un producto. Al revisar el historial HTTP (HTTP history) en Burp Suite, se identificó la petición GET /image?filename=30.jpg. Se envió esta petición específica al módulo Repeater para su manipulación.

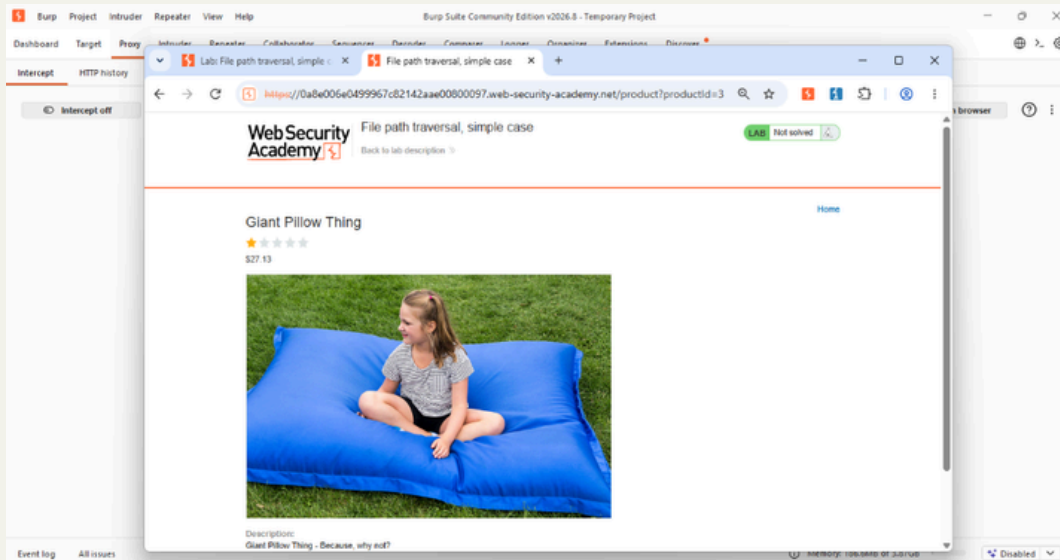


Figura 6.1 Pagina principal de la tienda en un apartado de "View details" de un producto.

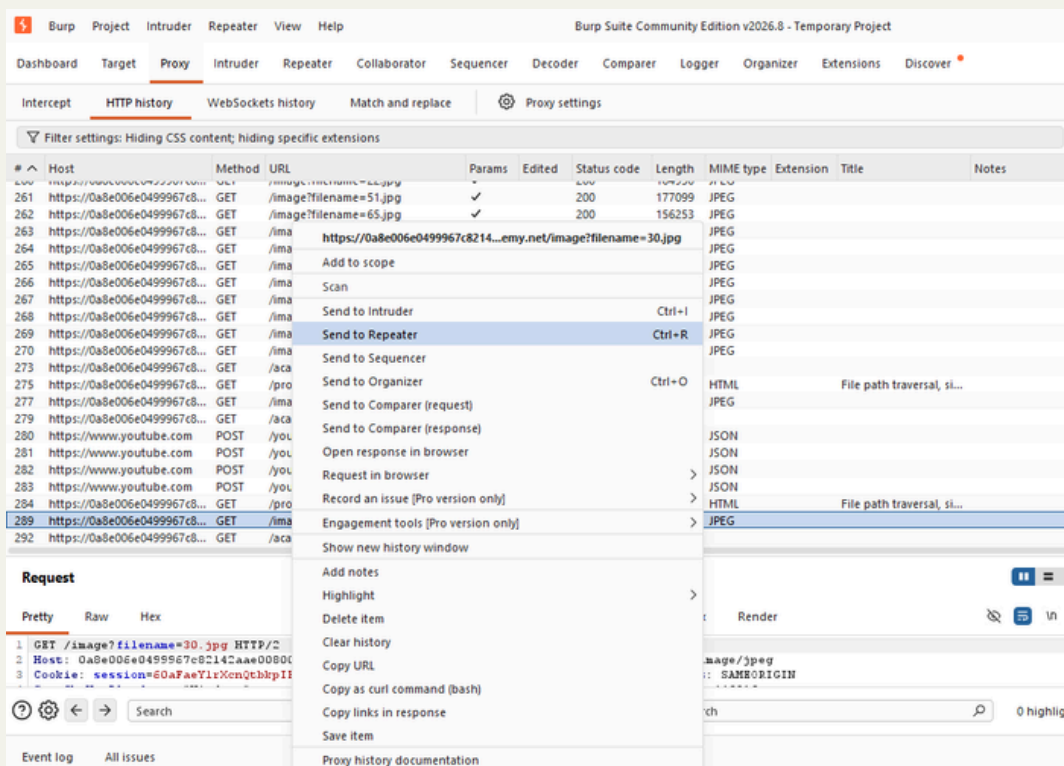


Figura 6.2 Se envió la petición a Repeater para su maipulación

Paso 3: Dentro de Repeater, se modificó el valor original del parámetro filename por el payload malicioso ../../etc/passwd y se envió la petición.

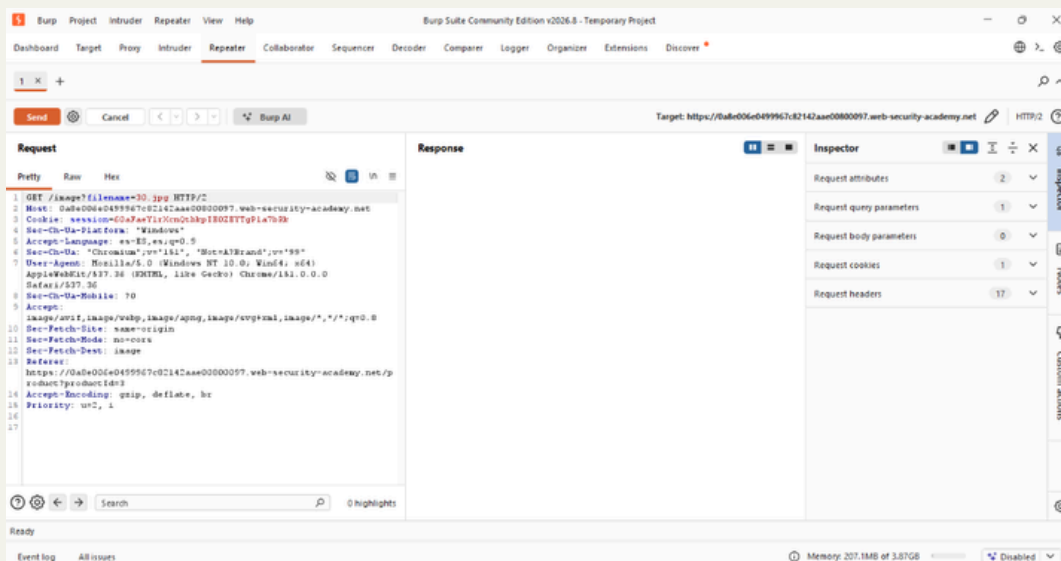


Figura 6.3 Parámetro filename original

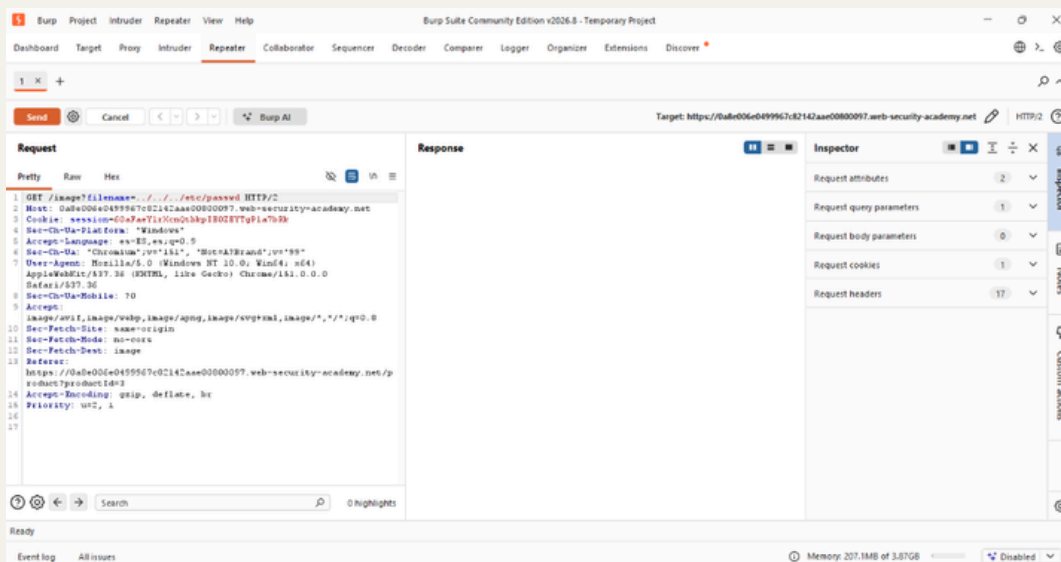


Figura 6.4 Parámetro filename modificado

Paso 4: Se analizó la respuesta del servidor en la que se observó un código de estado HTTP/2 200 OK acompañado del contenido íntegro del archivo /etc/passwd del servidor Linux (mostrando los usuarios como root), confirmando la explotación exitosa.

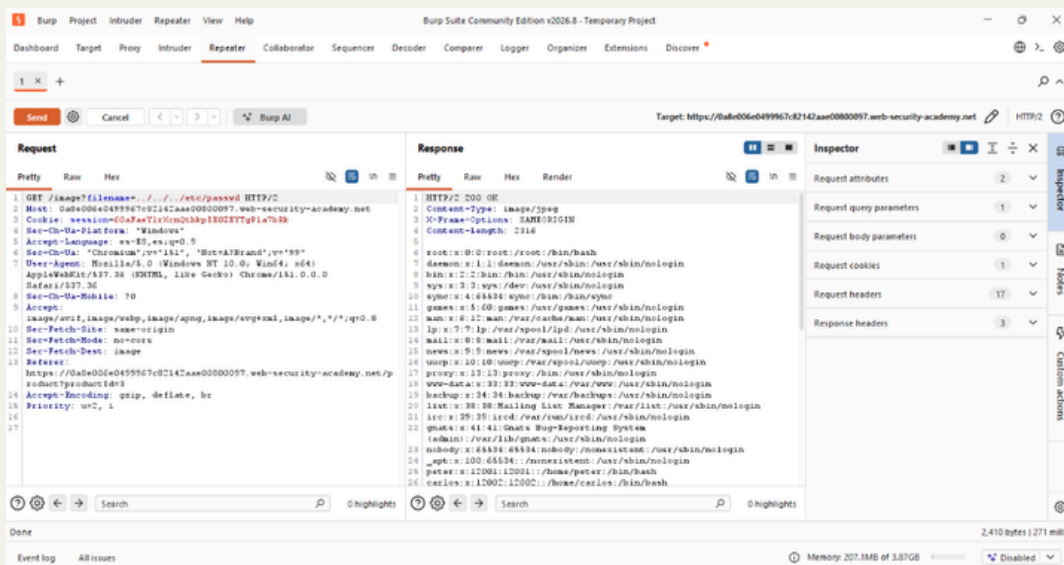


Figura 6.5 Respuesta del servidos al filename modificado

Paso 5: Finalmente, se recargó la página en el navegador principal, validando que el sistema de PortSwigger reconociera la vulnerabilidad explotada y mostrando el banner de "Lab Solved".

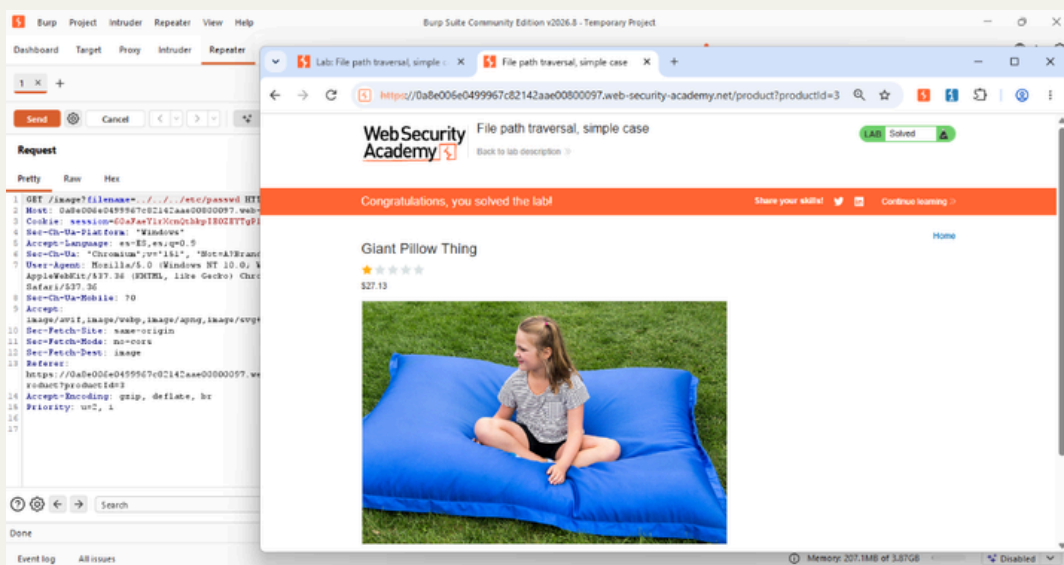


Figura 6.6 Laboratorio finalizado

EXPLICACIÓN DEL PAYLOAD

Payload utilizado: ../../etc/passwd

La aplicación web asume que las imágenes residen en un directorio específico (por ejemplo, /var/www/images/). Al no validar la entrada, el servidor concatena ciegamente la ruta base con el valor proporcionado por el usuario.

La secuencia ../ (dot-dot-slash) es un estándar en sistemas operativos tipo UNIX y Windows que indica al sistema que debe ascender un nivel en la jerarquía de directorios (directory climbing).

Al enviar ../../, se instruye al sistema de archivos a retroceder tres niveles desde el directorio base de imágenes hasta alcanzar la raíz del sistema operativo (/). A partir de la raíz, se especifica la ruta etc/passwd, lo que obliga al servidor a devolver el archivo que contiene la lista de usuarios del sistema Linux, demostrando un compromiso total en la confidencialidad de lectura.

MITIGACIÓN RECOMENDADA

Para remediar vulnerabilidades de Path Traversal, se recomienda implementar una estrategia de "Defensa en Profundidad" (Defense in Depth):

1. Evitar la entrada directa del usuario: La solución más efectiva es no pasar directamente los datos suministrados por el usuario a las API del sistema de archivos. En su lugar, se deben utilizar identificadores indirectos (p. ej., números enteros o hashes) mapeados a los archivos reales en el backend de forma estricta (OWASP Foundation, 2023).
2. Validación fuerte (Allow-listing): Si es indispensable usar nombres de archivo proporcionados por el usuario, se debe implementar una lista blanca estricta (allow-list) que solo permita caracteres alfanuméricos y rechace cualquier intento de inclusión de diagonales (/ o \) o puntos (.).
3. Canonicalización de rutas: Antes de acceder a cualquier archivo, la aplicación debe resolver la ruta absoluta real utilizando funciones seguras proporcionadas por el lenguaje de programación (como getCanonicalPath() en Java, realpath() en PHP o os.path.realpath() en Python). Una vez resuelta, el código debe verificar explícitamente que la ruta canónica resultante comience exclusivamente dentro del directorio base de almacenamiento esperado (CISA, 2022).

REFERENCIAS

- CISA. (2022). Improper Limitation of a Pathname to a Restricted Directory ('Path Traversal'). Cybersecurity and Infrastructure Security Agency. <https://www.cisa.gov/uscert/bsi/articles/knowledge/coding-practices/path-traversal>
- MITRE. (2023). CWE-22: Improper Limitation of a Pathname to a Restricted Directory ('Path Traversal'). Common Weakness Enumeration. <https://cwe.mitre.org/data/definitions/22.html>
- OWASP Foundation. (2023). Path Traversal. Open Worldwide Application Security Project. Payload utilizado: ../../../../etc/passwd